

BigPanda L1 Agent On-Prem Worker Security FAQ

1. Regulatory Alignment & Industry Standards

How does the On-Prem Worker align with HIPAA, PCI, and PII requirements?

The On-Prem Worker does not require PHI, PCI, or PII to deliver value. It operates within the customer's own infrastructure and does not transmit such data to BigPanda unless customer-authored runbooks explicitly gather and return it.

As part of the shared responsibility model, customers are responsible for ensuring their runbooks comply with applicable data handling requirements and should scope runbooks appropriately to avoid collecting or exposing sensitive data such as PHI, PII, or PCI information.

BigPanda's data redaction service is available for customers with HIPAA compliance requirements.

Does the On-Prem Worker address EU AI Act requirements?

The On-Prem Worker supports BigPanda's AI-powered incident triage capabilities, which are classified as a Limited Risk system under the EU AI Act. The worker itself is an execution engine operating under customer-defined runbooks. AI-generated workflows include transparent reasoning and source context, consistent with EU AI Act principles.

- Transparency through reasoning explanations in the AI Triage Master Agent workflow
- Human oversight: customers author and review all runbooks before deployment
- Bias detection through user feedback systems in the BigPanda platform
- Regular security reviews and risk assessments (Ref: BigPanda AI Security Governance Policy)

How does the On-Prem Worker support GDPR compliance?

The On-Prem Worker processes data in-place within the customer's environment and only returns structured diagnostic summaries, not raw data exports, to the customer org in their selected region.

What governance and certifications back the On-Prem Worker?

The On-Prem Worker development and release processes are within scope of BigPanda's SOC 2 Type II audit, covering security, availability, and confidentiality trust service criteria. BigPanda's AI controls and governance are aligned to NIST AI RMF (govern, map, measure, manage) and OWASP LLM Top 10.

2. Data Processing & Residency

What is the On-Prem Worker and where does it run?

The BigPanda On-Prem Worker is a lightweight, customer-deployed Docker agent that executes customer-authored runbooks within the customer's own infrastructure, whether on-premises data centers, private clouds, or public cloud environments. It acts as the execution engine for automated collection of diagnostic and contextual data related to incidents.

What data does the On-Prem Worker process?

The On-Prem Worker collects only the diagnostic and contextual information defined by the customer's runbooks, such as system state, log excerpts, configuration details, and operational telemetry relevant to the incident, returning only the resulting structured diagnostic findings to BigPanda over an encrypted connection.

The solution operates on a read-only, information-gathering model, processing data in place within the customer's environment and taking no actions to modify, update, delete, move, or write data unless explicitly directed by a customer-authored runbook.

Where is data processed and what is the residency?

The On-Prem Worker processes data entirely within the customer's own infrastructure. No raw customer data is replicated or relocated to BigPanda systems. Structured diagnostic results are transmitted to BigPanda's platform, available in US and EU regions. Customers select their preferred region and all platform-side processing, including AI triage, remains within that region.

Does the On-Prem Worker support regional isolation?

Yes. The worker itself runs in the customer's environment. For platform-side AI processing, customers choose whether data is processed and stored in the US or EU BigPanda region, ensuring EU-only processing is available end-to-end.

What happens to execution results produced by the On-Prem Worker?

Structured diagnostic results are transmitted from the worker to the BigPanda Temporal server over mTLS and processed by the AI Sub-Agent and AI Triage Master Agent. Results are written to the incident ticket in BigPanda as runbook steps executed and information gathered.

The worker does not persist any data at rest. Execution context, gathered information, and credentials exist only in memory for the duration of the runbook execution. Upon completion or failure, all in-memory data is released.

Can we review the On-Prem Worker's architecture and data flows?

Yes. The BigPanda On-Prem Worker architecture and data flows are available in our Customer Trust Center at <https://trust.bigpanda.io>.

3. Data Privacy, Retention & Sensitive Data Handling

Does the On-Prem Worker use our data to train AI models?

No. Customer data is never used to train, retrain, or improve foundation models. Prompts and completions are processed under enterprise Zero Data Retention terms with all LLM providers, which is Enterprise Contract bound.

Note: BigPanda does not use customer data to train global models across any product.

What are the retention policies of the On-Prem Worker's AI vendors?

- **OpenAI or Azure OpenAI (LLM):** Zero Data Retention; requests/responses are temporarily cached in memory, not written to disk, and deleted after processing.

Note: The On-Prem Worker itself does not interact with LLM vendors directly. The AI Triage Master Agent on the BigPanda platform generates the workflow, which is then dispatched to the worker via the Temporal server.

How is sensitive operational data protected?

Data is encrypted in transit (TLS 1.2+) between customer endpoints and BigPanda, and at rest (AES-256) with AWS KMS (FIPS 140-3). Keys are rotated annually. The On-Prem Worker itself holds no data at rest. All execution context, collected information, and credentials are held only in memory for the duration of the task and are automatically released upon completion or failure.

4. AI Security Controls & Threat Protections

How does the On-Prem Worker defend against AI-specific threats like prompt injection?

BigPanda implements OWASP LLM Top 10 controls across the AI triage pipeline that generates workflows dispatched to the On-Prem Worker:

- Constrained model behavior with strict context adherence in the AI Triage Master Agent
- Input validation and output format enforcement for generated workflows before dispatch to the worker
- Privilege control with least privilege access; the worker assumes only the customer-defined role
- Customer-authored runbooks define all worker behavior. BigPanda does not inject or modify runbook logic

How is the On-Prem Worker protected against data leakage or cross-tenant access?

The On-Prem Worker is a customer-deployed agent operating within the customer's own environment using customer-provisioned credentials. Cross-tenant access is architecturally prevented as the worker has no awareness of or access to any other customer's infrastructure or data.

On the BigPanda platform side, permission-aware vector stores, strict logical tenant partitioning, and immutable retrieval logs are enforced to prevent cross-tenant data access.

How does the On-Prem Worker reduce hallucinations and ensure accuracy?

The AI Triage Master Agent generates structured workflows using customer-defined runbooks, VectorDB content, and Neo4j topology data, with the accuracy and effectiveness of its recommendations dependent on the quality and currency of the customer-maintained data sources.

Does the On-Prem Worker act autonomously in our environment?

The On-Prem Worker's primary function is read-only information gathering as defined by customer-authored runbooks. It does not remediate, modify, or alter any systems or data by default. Where a runbook explicitly includes write actions for a documented, approved purpose, those

actions are bounded by the permissions of the customer-controlled assumed role, not determined by the LLM.

BigPanda recommends applying read-only permissions to assumed roles and ensuring all runbooks undergo peer review, version control, and testing prior to being associated with production incident types.

How are models tested and validated?

BigPanda maintains formal software development and change management processes to help ensure all application enhancements and production changes are properly designed, tested, reviewed, approved, and securely implemented.

These processes are guided by industry-recognized security and development best practices to support secure, reliable, and high-quality service delivery. This includes adherence to established frameworks and standards such as OWASP guidance and AWS Security Best Practices.

In addition, BigPanda conducts annual third-party penetration testing of web applications and our external network. BigPanda AI applications, including the triage pipeline that generates worker workflows, undergo annual third-party adversarial/AI red-team testing.

5. Access Control, Identity & Audit Logging

How is RBAC enforced?

Role-based access control (RBAC) and least-privilege controls are applied. The On-Prem Worker does not maintain standing credentials to customer systems. All access is obtained through role assumption, where the worker requests temporary, scoped credentials from the customer's identity provider at the time of execution.

- **Just-In-Time (JIT) Access:** The worker assumes a customer-defined role at runtime. No perpetual or standing credentials are maintained.
- **Least Privilege:** The customer scopes the assumed role to only the systems and data required by their runbooks.
- **No Credential Storage:** Credentials are held in memory only for the duration of runbook execution and released upon completion.
- **Segregation of Duties:** Customers fully control credential rotation and role provisioning according to their internal security requirements.

What audit trails are available?

BigPanda logs the end-to-end execution of On-Prem Worker operations within our platform. Customers are responsible for logging On-Prem Worker operations within their own environment.

Who has access to our data?

BigPanda does not have direct access to customer infrastructure. The On-Prem Worker runs in the customer's environment using credentials the customer provisions. Our internal access management for platform environments is founded on a Zero Trust Network Architecture.

- **Just-In-Time (JIT) Access:** Employees do not have perpetual access to production environments. Temporary, privileged access is granted to perform specific, approved tasks.

- **Least Privilege:** Individuals are granted the minimum access required to perform their job, and no more.
- **Segregation of Duties:** The individual approving a change or access request must be separate from the individual initiating it.

6. AI Governance & Vendor Risk Management

How are AI vendors selected and managed?

All vendors undergo a security review in accordance with BigPanda's Third-Party Vendor Management Policy, including at least annual assessments, and are covered by appropriate data processing agreements. All third-party AI vendors are contractually bound to Zero Data Retention.

Customers are notified in advance of new or changed vendors to support their risk assessment processes. This aligns to interagency third-party risk guidance for regulated industries.

How do users and admins control On-Prem Worker behavior?

Customers control On-Prem Worker behavior entirely through runbook authoring and the permissions assigned to the associated execution role, allowing them to define both the actions performed and the level of access granted.

What is the shared responsibility model?

BigPanda is responsible for the security of the worker software itself. The customer is responsible for the security of the environment in which it runs and the access it is granted.

BigPanda Responsibilities	Customer Responsibilities
Secure Development Lifecycle (SDLC) for worker software	Runbook authoring, review, and maintenance
Worker software vulnerability management	Role provisioning and least-privilege scoping
Secure communication protocol (mTLS)	Credential and identity infrastructure
Security updates and advisories for the worker	Network security and host/container security
Audit trail within BigPanda platform	Worker updates and patch management
AI triage pipeline security and LLM vendor governance	Monitoring and alerting in the customer environment